

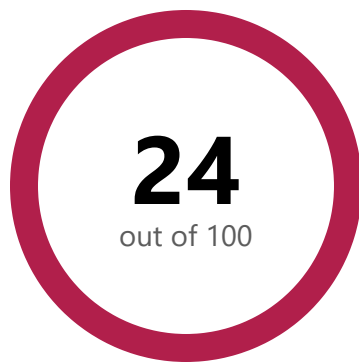
SAAS READINESS ASSESSMENT

vitaviva/ compose-weather

Assessment date: 28 August 2026

Assessor: Git-Ape / GitHub Copilot

Commit: `f05674aed9b461f7a8ea9a067a244064cbfa3c53`



Classification: Not SaaS-ready. The repository is a device-local Android Jetpack Compose demonstration using static mock data. It contains no cloud service, tenant boundary, Azure infrastructure, identity plane, billing integration, or production operations model.

1. Executive Summary

24/100

Composite readiness

Evidence-weighted score for conversion into a production multi-tenant SaaS.

0

Azure resources

No ARM, Bicep, Terraform, Azure deployment configuration, or hosted workload was found.

1.4/5

WAF average

Operational CI is the main positive signal; cloud pillars are otherwise unevidenced.

Composite calculation

Category	Score	Weight	Contribution
Azure Well-Architected	28/100	25%	7
Azure CAF	20/100	10%	2
SaaS maturity	20/100	20%	4
Regulatory readiness	20/100	25%	5
SRE readiness	20/100	10%	2
Cost management	40/100	10%	4
Weighted total			24/100

Top 5 production gaps

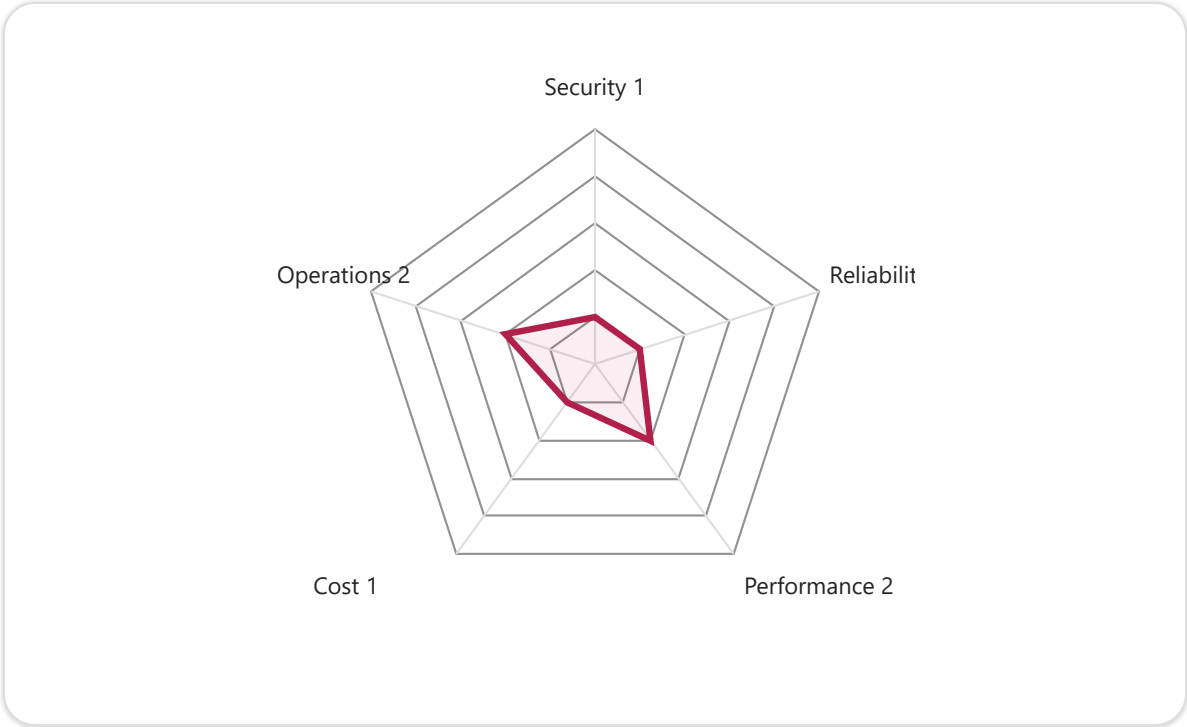
1. **High:** No server-side product or tenant definition.
2. **High:** No identity, authorization, tenant-context validation, or isolation tests.
3. **High:** No Azure architecture, IaC, governance, or environment promotion model.
4. **High:** Placeholder tests do not validate product behavior.
5. **High:** Obsolete 2021 Android and CI dependencies increase security and maintenance risk.

Top 5 strengths

1. No current cloud attack surface or Azure spend.
2. No Android Internet permission is declared.
3. CI runs formatting, build, lint, and emulator jobs.
4. Accessibility semantics are present in the Compose UI.
5. Unused Android build features are disabled.

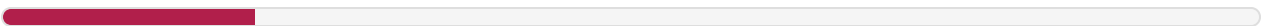
Decision: Treat this repository as a UI prototype, not as an assessable SaaS implementation. Before any production claim, define the service architecture and implement an independently secured backend. No Critical finding is assigned to the current offline demo; the High findings become release blockers if SaaS conversion is intended.

2. Azure Well-Architected Scorecard

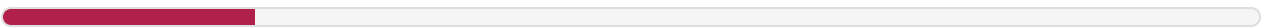


Scores and evidence

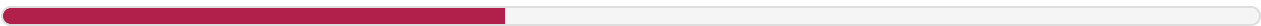
Security: 1/5



Reliability: 1/5



Performance efficiency: 2/5



Cost optimization: 1/5



Operational excellence: 2/5



Pillar	Evidence-based assessment	Priority improvement
Security	No identity, authorization, tenant isolation, secrets management, or backend. <code>AndroidManifest.xml:13-35</code>	Threat model and server-validated tenant identity.
Reliability	No SLO, resilience, backup, DR, health model, or meaningful assertions. <code>ExampleUnitTest.kt:18-25</code>	Define service objectives and failure-mode tests.
Performance	Local static data avoids network latency, but no profiling or scale evidence. <code>Mock.kt:24-244</code>	Profile mobile UI; load-test any future APIs.
Cost	No current Azure resources or charges; no future unit economics.	Model cost per tenant and set budgets before provisioning.
Operations	Basic CI exists, but no delivery promotion, observability, runbooks, or IaC. <code>Check.yaml:1-74</code>	Modernize CI and implement repeatable environments.

3. Azure CAF Compliance

Area	Score	Status	Evidence / gap
Landing zones	1/5	Not addressed	No management-group, subscription, environment, or connectivity design.
Naming and tagging	1/5	Not addressed	No Azure resource names or mandatory tags exist.
Governance and policy	1/5	Not addressed	No Azure Policy or compliance-as-code artifacts.
Identity baseline	1/5	Not addressed	No Entra tenant strategy, workload identities, or RBAC model.
Environment promotion	1/5	Not addressed	CI builds only on pushes to main; no dev/test/prod deployment flow.

CAF score: 1/5. If SaaS conversion proceeds, establish a minimal platform/workload subscription model, policy baseline, managed identities, resource naming, budgets, and Bicep-managed dev/test/prod environments.

4. SaaS Maturity

Capability	Score	Assessment	Required evidence
Tenant definition and isolation	1/5	No tenant concept or server-side boundary.	Tenancy ADR; compute/data/identity/network isolation map; escape tests.
Tenant lifecycle	1/5	No signup, provisioning, entitlement, migration, or deletion workflow.	Idempotent lifecycle state machine and reconciliation jobs.
Fulfillment and metering	1/5	No marketplace events, usage dimensions, or reconciliation.	Fulfillment API integration and auditable meter event schema.
Marketplace readiness	1/5	No offer, plans, pricing, legal artifacts, or certification evidence.	Partner Center checklist and private-preview gate.
Deployment topology	1/5	No backend topology, deployment stamps, placement, or rollback strategy.	Versioned IaC, dependency graph, capacity and migration policy.

Recommended starting model: For a new service, begin with shared compute and logically isolated data only after tenant context is derived from authenticated identity and enforced at every data operation. Use deployment stamps when tenant density, regional residency, or blast-radius limits require them.

5. Regulatory Compliance Matrix

This is a repository evidence review, not a certification or audit opinion. Azure-specific controls are not applicable to the current offline app; they remain unimplemented requirements for a future SaaS service.

Control ID	Description	NIST	CIS	PCI	HIPAA	SOC 2	FedRAMP	Status
ID-01	Authenticated identities and least privilege	AC, IA	IAM	7, 8	Access	CC6	AC, IA	Not implemented
ISO-01	Tenant authorization and cross-tenant isolation	AC-3, SC-2	IAM	7	Access	CC6	AC-3	Not implemented
ENC-01	Encryption in transit and at rest	SC-8, SC-13	Storage	3, 4	Security	CC6	SC-8, SC-13	Not assessable
LOG-01	Audit logging and monitoring	AU-2, AU-6	Logging	10	Audit	CC7	AU	Not implemented
VUL-01	Vulnerability and dependency management	RA-5, SI-2	Compute	6, 11	Risk	CC7	RA-5	Weak
BCP-01	Backup, recovery, and continuity	CP-9, CP-10	Backup	12	Contingency	A1	CP	Not implemented
IR-01	Incident response	IR family	Logging	12	Breach	CC7	IR	Not implemented
SDLC-01	Secure change and release controls	CM-3, SA-11	Governance	6	Integrity	CC8	CM, SA	Minimal
PRV-01	Privacy, retention, and deletion	SI, PT	Governance	3	Privacy	P series	SI	Not implemented

Control ID	Description	NIST	CIS	PCI	HIPAA	SOC 2	FedRAMP	Status
GOV-01	Policy, ownership, and evidence retention	PM, PL	Governance	12	Policy	CC1-CC5	PL, PM	Not implemented

Framework	Score	Readiness statement
CIS Azure Foundations v2.1	1/5	No Azure scope exists; no Azure hardening evidence.
NIST 800-53 Rev 5 Moderate	1/5	Technical and administrative control evidence is absent.
PCI DSS v4.0	1/5	No CDE is identified; do not introduce payment data without scope design.
HIPAA / HITRUST	1/5	No PHI claim, BAA, risk analysis, or safeguard evidence.
SOC 2 Type II	1/5	No operating-effectiveness evidence period or control ownership.
FedRAMP Moderate	1/5	No authorization boundary, SSP, FIPS evidence, POA&M, or continuous monitoring.
ISO 27001:2022	1/5	No ISMS scope, risk treatment, Statement of Applicability, or audit evidence.

6. Security Deep-Dive

Verified current-state controls

Control	Status	Evidence	Interpretation
Network access	Limited	<code>AndroidManifest.xml:13-35</code> has no Internet permission.	The demo has no declared network access; this is not evidence of SaaS API security.
Debug signing separation	Applied for debug	<code>app/build.gradle:19-32</code>	Bundled debug credentials are scoped to debug builds; production signing is undefined.
Device backup	Review required	<code>AndroidManifest.xml:17</code> sets <code>allowBackup="true"</code> .	Define extraction/backup rules before storing tokens or customer data.
Release hardening	Not applied	<code>app/build.gradle:33-36</code> sets <code>minifyEnabled false</code> .	Enable and test R8 for production releases.
Supply chain	Weak	Old Gradle, Compose, Kotlin, JCenter, and v1/v2 GitHub Actions.	Upgrade, pin actions by SHA, scan dependencies, and produce an SBOM.

Future tenant threat model

Threat	Required control	Required test
Client supplies another tenant's identifier	Derive tenant context from authenticated claims and server-side membership.	Horizontal privilege-escalation tests on every tenant-scoped API.
Cross-tenant data query or cache collision	Mandatory tenant partition key and repository-layer policy.	Negative tests across database, cache, search, export, and logs.
Asynchronous context loss	Signed/internal tenant metadata on messages; authorize again at consumption.	Poisoned-message and tenant-substitution tests.
Mobile secret extraction	No service credentials in APK; OAuth authorization code with PKCE.	APK secret scan and token replay tests.
Privileged support access	JIT access, audited impersonation, approval, and scoped break-glass.	Privilege boundary and immutable audit-log tests.

laC security and Azure Policy: Not applicable to current state. No Azure resource definitions exist, so no Azure security property can be marked Applied, no policy definition can be mapped to a resource, and no policy assignment coverage can be inferred. Subscription state was not queried because no target subscription was supplied.

7. SRE Readiness

Area	Score	Current evidence	Production baseline
SLO / SLI	1/5	None.	Availability, latency, correctness, freshness, and tenant-level objectives.
Observability	1/5	Build reports only.	Correlated metrics, logs, traces, audit events, synthetic tests, and alert ownership.
Autoscaling / capacity	1/5	No service workload.	Stamp capacity, tenant density, scale triggers, quotas, and load tests.
DR / backups	1/5	No service data or recovery design.	RTO/RPO, backups, restore tests, regional evacuation, and data reconciliation.
Noisy-neighbor controls	1/5	No shared platform.	Per-tenant throttles, concurrency limits, queue isolation, and attribution.
Delivery operations	2/5	Build and emulator workflow on main.	PR gates, signed releases, progressive delivery, rollback, runbooks, and ownership.

SRE score: 1/5. The current CI workflow is useful prototype hygiene but does not demonstrate service reliability.

8. Cost Analysis

\$0

Current Azure monthly estimate

No Azure resources were found. This is an evidence statement, not an Azure Retail Prices API estimate.

Unknown

Future SaaS cost

No region, SKU, traffic, storage, retention, availability, or tenant-density assumptions are defined.

Cost controls required before architecture approval

- Define workload units: monthly active tenants, requests, weather-provider calls, storage, telemetry, and egress.
- Model shared versus siloed tenant resources and deployment-stamp density.
- Estimate verified retail prices only after resource types, SKUs, regions, and quantities are chosen.
- Implement mandatory tags, budgets, anomaly alerts, showback, and cost-per-tenant telemetry.
- Set log retention and sampling deliberately; observability is often a material variable cost.

No prices were fabricated or queried because the repository contains no Azure billable resource configuration.

9. 30 / 60 / 90 Day Action Plan

Window	Priority	Action	Owner	Effort	Exit evidence
0-30	High	Define product, tenant, data classification, compliance scope, SLO, RTO/RPO, scale, and budget requirements.	Product + Architecture	M	Approved requirements and tenancy ADR.
0-30	High	Upgrade Android, Kotlin, Compose, Gradle, target SDK, repositories, and CI actions.	Mobile	M	Supported versions, PR build, dependency scan, SBOM.
0-30	High	Replace placeholder tests and enable release shrinking plus secure backup rules.	Mobile + Security	M	Behavioral tests and hardened release build.
31-60	High	Build an identity-aware API using managed identities and Key Vault; keep credentials out of the app.	Platform	L	Threat-modeled API and auth integration tests.
31-60	High	Implement Bicep-managed dev/test/prod landing zones, policy, tags, budgets, and observability.	Cloud Platform	L	Reviewed IaC and successful non-production deployment.
31-60	High	Implement tenant partitioning, lifecycle state machine, entitlements, and reconciliation.	SaaS Platform	L	Cross-tenant negative tests and lifecycle tests.
61-90	Medium	Load-test tenant density, throttling, autoscaling, and failure domains.	SRE	M	Capacity limits and scaling runbooks.
61-90	Medium	Test backups, restore, rollback, incident response, and regional recovery where justified.	SRE + Security	L	Exercise results meeting RTO/RPO.
61-90	Medium	Design Marketplace offer, fulfillment, metering, and financial reconciliation if commercialization requires it.	Commercial + Platform	L	Private-preview launch gate.

10. Appendix

Full findings register

ID	Severity	Finding	Evidence	Timeline
F-01	High	No SaaS service, identity, authorization, or tenant boundary.	AndroidManifest.xml:13-35 ; Mock.kt:24-244	Before SaaS build
F-02	High	No Azure IaC, governance, security, policy, or deployment topology.	Repository inventory	Before cloud deploy
F-03	High	Obsolete and prerelease toolchain components.	build.gradle:18-34 ; app/build.gradle:67-80	30 days
F-04	High	Tests are placeholders without meaningful assertions.	ExampleUnitTest.kt:18-25 ; ExampleInstrumentedTest.kt:24-37	30 days
F-05	Medium	Application backup is enabled without explicit production data rules.	AndroidManifest.xml:17	60 days
F-06	Medium	Release minification is disabled.	app/build.gradle:33-36	60 days
F-07	Medium	CI actions are obsolete and workflow is push-only.	Check.yaml:3-7,14-29,50-71	60 days
F-08	Medium	No mobile performance profiling despite continuous animation and fixed large widths.	WeatherView.kt:140-143,268-285,458-468	90 days
F-09	Low	Bundled standard debug keystore must remain non-production only.	app/build.gradle:19-32	Backlog guardrail

Repository inventory

- Application: Kotlin Android app, Jetpack Compose beta-era toolchain.
- Data: static, in-process mock weather values.
- Infrastructure: none found (no ARM, Bicep, Terraform, Dockerfile, or Azure deployment artifacts).

- CI/CD: one GitHub Actions workflow for build, lint, and emulator tests.
- Existing SaaS assessment artifacts: none found.

Methodology and limitations

The assessment used repository evidence at the stated commit and the 1-5 rubric defined by the SaaS Assessment Report workflow. The composite score weights WAF 25%, CAF 10%, SaaS maturity 20%, regulatory readiness 25%, SRE 10%, and cost 10%. Missing evidence is scored as not addressed; it is not treated as proof of absence outside the repository.

No Azure subscription, deployed resources, runtime telemetry, penetration-test results, organizational policies, contracts, or operating records were supplied. Consequently, Azure Policy, live compliance, security posture, and pricing could not be verified. Framework mappings are readiness indicators, not certifications, legal advice, or an attestation of compliance.

Generated as a self-contained HTML report using the Clawpilot theme. Source repository: github.com/vitaviva/compose-weather.